

المرجع الخليجي الشامل في الأمن السيبراني

الأسس والضوابط والعمليات والتنظيم

علي العنزي

2026

المرجع الخليجي الشامل في الأمن السيبراني

علي العنزي

الطبعة الأولى 2026

جميع الحقوق محفوظة للمؤلف، فلا يجوز نسخ أي جزء من هذا الكتاب أو تخزينه أو نقله بأي وسيلة دون إذن كتابي مسبق منه، ويستثنى من ذلك الاقتباس القصير في المراجعات والدراسات مع الإشارة إلى المصدر.

الرقم الدولي المعياري للكتاب ISBN 9798178685440، النسخة الورقية بطباعة مستقلة Independently published.

تصميم الغلاف والأشكال من عمل المؤلف.

موقع الكتاب والتدريبات المرافقة له على gulfcyber.3li.info

للتواصل مع المؤلف: info@3li.info

المحتويات

xxv	افتتاحية
xxvii	المقدمة
xxix	كيف تقرأ هذا الكتاب
xxxi	شكر وتقدير

1 الباب الأول: الأسس

3	1 مدخل إلى أمن المعلومات
4	1.1 ما المعلومات ولماذا نحميها
6	2.1 الخصائص الثلاث: السرية والسلامة والتوافر
9	3.1 أمن المعلومات والأمن السيبراني وحماية البيانات . .
10	4.1 المفردات الأربع: الأصل والتهديد والثغرة والخطر . .

5.1	مبادئ لا تتغير	11
6.1	أنواع الضوابط	12
7.1	لماذا تُخترق المؤسسات مع كل هذا	13
8.1	الأمن عملية مستمرة لا منتج يُشترى	14
2	التحديات والمهاجمون	19
1.2	من يهاجمنا ولماذا	20
2.2	تشریح الهجوم	21
3.2	الهندسة الاجتماعية	22
4.2	البرمجيات الخبيثة	24
5.2	هجمات الشبكات والأنظمة	25
6.2	التهديد الداخلي	26
7.2	مشهد التهديدات في الخليج	27
8.2	كيف يفكر المدافع	28
3	إدارة المخاطر	33
1.3	لماذا نبدأ من الخطر لا من التقنية	34
2.3	خطوات إدارة المخاطر	35
3.3	جرد الأصول وتصنيفها	36
4.3	تحديد التهديدات والثغرات	37

5.3	تحليل المخاطر بين النوعي والكمي	38
6.3	معالجة المخاطر	39
7.3	شبهة المخاطر وتحملها	40
8.3	سجل المخاطر الحي	40
9.3	مخاطر الأطراف الثالثة وسلسلة التوريد	42
10.3	المخاطر في سياقنا الخليجي	42
4	الحوكمة والسياسات والأطر والامثال	49
1.4	ما الحوكمة ولماذا تفشل البرامج بدونها	50
2.4	أين يقع أمن المعلومات في الهيكل	51
3.4	هرم الوثائق	52
4.4	الأطر والمعايير الدولية	53
5.4	المشهد التنظيمي في الخليج	55
6.4	الامتثال ليس أمناً	59
7.4	قياس البرنامج وتقريره	59
8.4	التأكيد والتدقيق	60

65 الباب الثاني: الضوابط التقنية

67 5 التشفير

- 68 1.5 ما يفعله التشفير وما لا يفعله
- 68 2.5 التشفير المتماثل
- 69 3.5 التشفير غير المتماثل
- 70 4.5 دوال التجزئة ورموز المصادقة
- 71 5.5 التوقيع الرقمي
- 71 6.5 البنية التحتية للمفاتيح العامة
- 72 7.5 تأمين النقل بروتوكول TLS
- 73 8.5 كيف تختار الخوارزمية وطول المفتاح
- 74 9.5 التشفير أثناء الاستخدام والحوسبة السرية
- 75 10.5 أخطاء التطبيق التي تبطل أقوى الخوارزميات
- 76 11.5 إدارة المفاتيح ودورة حياتها
- 76 12.5 التشفير في واقعنا
- 77 13.5 ما بعد الحوسبة الكمية

83 6 الهوية والمصادقة وإدارة الصلاحيات

- 84 1.6 المصطلحات الأربعة

2.6	عوامل المصادقة	84
3.6	كلمات المرور ما زالت معنا	86
4.6	الدخول الموحد والاتحاد	87
5.6	نماذج التحكم في الوصول	87
6.6	إدارة الحسابات المميزة	88
7.6	دورة حياة الهوية	89
8.6	الهويات غير البشرية	89
9.6	حوكمة الهوية وإدارتها	90
10.6	هوية العملاء	90
11.6	الدليل النشط وما حوله	91
12.6	انعدام الثقة	92
13.6	الهوية الرقمية الوطنية في الخليج	92

7 أمن الشبكات 99

1.7	الشبكة من منظور المدافع	100
2.7	التجزئة والمناطق	101
3.7	الجدران النارية بأجياها	102
4.7	كشف التسلل ومنعه	102
5.7	الوصول عن بعد والشبكات الخاصة الافتراضية	103

6.7	أمن نظام أسماء النطاقات	104
7.7	الشبكات اللاسلكية	104
8.7	التحكم في الوصول إلى الشبكة والبروتوكولات القديمة .	105
9.7	الحماية من حجب الخدمة	106
10.7	مراقبة حركة الشبكة	106
11.7	الفروع والعمل من أي مكان	107
12.7	الشبكة داخل مركز البيانات	107
13.7	مثال تطبيقي: تجزئة شبكة مؤسسة متوسطة	108
14.7	الشبكة في المؤسسة الخليجية	109

8 أمن الأنظمة ونقاط النهاية 115

1.8	التهية الآمنة والتحصين	116
2.8	إدارة الثغرات والتحديثات	117
3.8	من مكافحة الفيروسات إلى كشف نقاط النهاية والاستجابة	118
4.8	الامتياز على الجهاز	119
5.8	الأجهزة المحمولة	120
6.8	التشفير على الأجهزة والوسائط	120
7.8	التسجيل على مستوى النظام	121

121	8.8	الخوادم والبيئات الافتراضية
122	9.8	الأنظمة القديمة التي لا تموت
122	10.8	نقاط النهاية في المؤسسة الخليجية

9 أمن التطبيقات والتطوير الآمن 129

130	1.9	أشهر ثغرات التطبيقات
132	2.9	دورة التطوير الآمنة
133	3.9	نمذجة التهديدات للتطبيقات
133	4.9	الاختبارات الأمنية للتطبيقات
134	5.9	أمن واجهات البرمجة
135	6.9	أمن سلسلة توريد البرمجيات
135	7.9	الأمن في خط التسليم المستمر
136	8.9	الحماية في زمن التشغيل
136	9.9	التطبيقات في المؤسسة الخليجية

10 أمن الحوسبة السحابية 143

144	1.10	نماذج الخدمة والنشر
145	2.10	المسؤولية المشتركة
146	3.10	الهوية في السحابة
147	4.10	الهيئة الخاطئة وإدارة الوضع الأمني

147	5.10 الحاويات والخدمات المصغرة
148	6.10 حماية البيانات في السحابة
148	7.10 الشبكات السحابية
149	8.10 المراقبة والتسجيل في السحابة
149	9.10 أمن البرمجيات تخدمة
150	10.10 الحوكمة والامتثال والتوطين في الخليج
151	11.10 استراتيجية الخروج ومخاطر التركيز
157	11 أمن البيانات والخصوصية
158	1.11 التصنيف أساس كل شيء
160	2.11 دورة حياة البيانات وضوابطها
161	3.11 منع تسريب البيانات
161	4.11 التشفير والإخفاء والترميز
162	5.11 النسخ الاحتياطي والإتلاف الآمن
163	6.11 مبادئ الخصوصية
164	7.11 تقييم الأثر على الخصوصية
164	8.11 خروقات البيانات والإبلاغ عنها
165	9.11 البيانات في المؤسسة الخليجية
171	12 أمن الأنظمة الصناعية وإنترنت الأشياء

172	1.12 عالم مختلف بأولويات معكوسة
173	2.12 نموذج يردو والمناطق والقنوات
174	3.12 البروتوكولات الصناعية
175	4.12 التهديدات على قطاعات المنطقة
175	5.12 الضوابط الأساسية
176	6.12 دراسة حالة: محطة تحلية اقراضية
177	7.12 المراقبة دون تعطيل
177	8.12 أمن إنترنت الأشياء
178	9.12 البنية التحتية الحيوية في الخليج
178	10.12 الاستجابة للحوادث في البيئات الصناعية

13 المعمارية الأمنية 185

186	1.13 ما المعمارية الأمنية ولماذا
187	2.13 الأطر المعمارية
188	3.13 المبادئ المعمارية
189	4.13 الأنماط المعمارية الآمنة
190	5.13 معمارية انعدام الثقة
191	6.13 المعمارية السحابية ومنطقة الهبوط
192	7.13 مراجعة المعمارية في المؤسسة

193	8.13 قياس نضج المعمارية
194	9.13 المعمارية الأمنية في المؤسسة الخليجية
194	10.13دراسة حالة: بنك يطلق تطبيق هاتف

201 الباب الثالث: العمليات والصمود

203	14 مراقبة الأمن والعمليات الأمنية
204	1.14 الرؤية قبل الأدوات
204	2.14 مركز العمليات الأمنية
205	3.14 السجلات
206	4.14 إدارة المعلومات والأحداث الأمنية
206	5.14 هندسة الكشف وحالات الاستخدام
207	6.14 الاستخبارات التهديدية
207	7.14 صيد التهديدات
208	8.14 الأتمتة والتنسيق
208	9.14 قياس أداء المركز
209	10.14الاستعانة بمزود خارجي
209	11.14مركز العمليات في المؤسسة الخليجية
210	12.14دراسة حالة: التنبيه الذي لم يُقرأ

15 الاستجابة للحوادث والتحقيق الرقمي 215

- 1.15 الحدث والحادثة والحرق 216
- 2.15 دورة الاستجابة 217
- 3.15 الاستعداد 218
- 4.15 الساعة الأولى 218
- 5.15 الكشف والتحليل 219
- 6.15 الاحتواء والاستئصال والتعافي 219
- 7.15 التواصل والإبلاغ التنظيمي 220
- 8.15 التحقيق الرقمي 221
- 9.15 الدروس المستفادة 221
- 10.15 التمارين 222
- 11.15 دراسة حالة: برمجية فدية في مؤسسة متوسطة 222

16 استمرارية الأعمال والتعافي من الكوارث 227

- 1.16 المرونة التشغيلية باعتبارها الهدف 228
- 2.16 تحليل أثر الأعمال 229
- 3.16 استراتيجيات التعافي 230
- 4.16 السحابة والمرونة 231
- 5.16 النسخ الاحتياطي في مواجهة الفدية 232

232	6.16 الخطط
233	7.16 التمارين والاختبارات
233	8.16 اضطرابات ليست سيرانية
234	9.16 قائمة تحقق للاختبار السنوي
234	10.16 الأطراف الثالثة والتركز
234	11.16 المرونة التشغيلية في الأطر الخليجية
235	12.16 دراسة حالة: فقدان مركز بيانات
241	17 العنصر البشري والتوعية الأمنية
242	1.17 لماذا يفشل التدريب التقليدي
242	2.17 من التوعية إلى السلوك إلى الثقافة
243	3.17 بناء برنامج التوعية
244	4.17 اختبارات التصيد المحاكاة
244	5.17 الرسالة التي تصل
245	6.17 القيادة والقدوة
245	7.17 أمن الموظفين من التعيين إلى المغادرة
246	8.17 الهندسة الاجتماعية في البيئة الخليجية
246	9.17 التوعية للعملاء والجمهور
247	10.17 التدريب بالمحاكاة والألعاب

11.17	الأمن في حياة الموظف الشخصية	247
12.17	دراسة حالة: حوالة مزورة	248
13.17	قياس البرنامج	248

الباب الرابع: آفاق

18 الذكاء الاصطناعي وأمن المعلومات

255	الذكاء الاصطناعي وأمن المعلومات
1.18	الذكاء الاصطناعي في يد المهاجم 256
2.18	الهجمات على نماذج اللغة والأنظمة المبنية عليها . . . 257
3.18	حوكمة استخدام الذكاء الاصطناعي في المؤسسة . . . 258
4.18	النماذج المدربة داخلياً 258
5.18	أسئلة قبل اعتماد أي أداة 259
6.18	الذكاء الاصطناعي في الدفاع 259
7.18	الأطر الناشئة 260
8.18	الاحتيايل على الأفراد والعائلات 261
9.18	دراسة حالة: المساعد الذي يقرأ البريد 261

19 المسيرة المهنية في أمن المعلومات

1.19	خريطة التخصصات	268
------	----------------	-----

269	2.19 المهارات التي تسبق كل شيء
269	3.19 الشهادات بقيمتها الحقيقية
270	4.19 بناء الخبرة قبل الوظيفة وبعدها
270	5.19 مسارات نموذجية
271	6.19 السيرة الذاتية والمقابلة
271	7.19 التعلم الذي لا يتوقف
272	8.19 سوق العمل الخليجي
272	9.19 دور الجامعات والجهات الحكومية
273	10.19 أخلاقيات المهنة
274	11.19 الخطوة الشخصية

281 الملاحق

281 قائمة تحقق للمؤسسة الصغيرة والمتوسطة

281	الهوية والحسابات
282	الأجهزة والأنظمة
282	الشبكة والوصول
282	البيانات والنسخ الاحتياطي
283	الناس

283	الاستعداد والامتحان
285	مسرد المصطلحات
297	المراجع والمصادر
297	الأطر والمعايير الدولية
298	الأطر والقوانين الخليجية
300	أبحاث المؤلف
301	الأدلة الفنية والتقارير
303	عن المؤلف

قائمة الأشكال

- 1.1 ثالث السرية والسلامة والتوافر 6
- 1.2 مراحل سلسلة القتل السيبرانية السبع 21
- 1.3 دورة إدارة المخاطر 35
- 1.4 هرم الوثائق من السياسات إلى الإرشادات 52
- 1.5 سلسلة الثقة في الشهادات الرقمية 71
- 1.6 العمليات الأربع لإدارة الهوية والوصول 84
- 1.7 مناطق الشبكة من الأقل ثقة إلى الأعلى حساسية 101
- 1.8 دورة إدارة الثغرات 117
- 1.9 الأمن في كل مرحلة من دورة التطوير 132
- 1.10 توزيع المسؤولية بين المزود والعميل 145

- 1.11 دورة حياة البيانات 160
- 1.12 مستويات نموذج بيردو والمنطقة الوسيطة 173
- 1.13 طبقات المعمارية الأمنية من الأعمال إلى التشغيل . . . 188
- 2.13 معمارية مرجعية لمؤسسة مالية بمناطقها ومكوناتها . . 190
- 3.13 أركان معمارية انعدام الثقة ونقاط القرار والإنفاذ . . . 191
- 4.13 منطقة الهبوط السحابية 192
- 5.13 مراحل مراجعة المعمارية من الاستقبال إلى التحقق . . 193
- 1.14 مسار المراقبة من المصدر إلى الاستجابة 204
- 1.15 دورة الاستجابة للحوادث 217
- 1.16 دورة بناء المرونة التشغيلية 229
- 1.17 من التوعية إلى الثقافة 243
- 1.18 ما يدخل إلى النموذج وما يخرج منه 257
- 1.19 عائلات التخصص في أمن المعلومات 268

قائمة الجداول

1.1	الخصائص الثلاث وما يحفظها	8
2.1	وظائف الضوابط الخمس	13
1.3	دورة إدارة المخاطر	36
2.3	الحقول الأساسية في سجل المخاطر	41
1.4	أشهر الأطر والمعايير وما يناسب كلاً منها	55
1.5	الخيارات التشفيرية المعتمدة لأشيع الحاجات	73
1.6	عوامل المصادقة الشائعة ومقاومتها للتصيد	85
1.7	تقسيم نموذجي لشبكة مؤسسة متوسطة	108
1.9	أشهر فئات ثغرات التطبيقات وضوابطها	131
1.10	توزيع المسؤولية بحسب نموذج الخدمة	146

1.11 مثال لمخطط تصنيف من أربعة مستويات 159

1.16 مثال على مخرجات تحليل أثر الأعمال 230

افتتاحية

كان الغيص في خليجنا ينزل إلى القاع وحياته معلقة بحبل يمسكه السيب فوق السطح، فإذا شد الغيص الحبل رُفِع وإذا أُرْخِيَ الحبل غرق، وكانت الديرة كلها معلقة بحبال كهذه، بثقة بين من ينزل ومن يمسك، وبمعرفة بالبحر تتوارثها الأجيال.

واليوم تتدلى حياتنا من حبال أخرى لا تُرى، أسلاك في قاع البحر وموجات في الهواء وشفرة في أجهزة لا تعرف الولاء، تمر عليها روايتنا وسجلاتنا الصحية وهوياتنا وأسرار شركائنا، ويدار بها الماء الذي نشربه والكهرباء التي تبرد بيوتنا والمال الذي نتعامل به، وصار الذي يمسك هذه الحبال ويحرسها هو من نسميه اليوم المختص في أمن المعلومات، وما هو بأقل ممن كان يمسك الحبل ثقةً ولا مسؤولية.

كُتِبَ هذا الكتاب لهؤلاء ولمن يريد أن يكون منهم، وكُتِبَ من داخل الميدان لا من بعيد، من غرف العمليات والمراجعات والحوادث والاجتماعات مع الجهات المنظمة، وكُتِبَ جواباً عن سؤال سمعته سنوات من الطالب والمهندس والمدير على السواء عن مرجع عربي يجمع المجال كله بلغتنا وأطرناءنا وأمثلتنا، فلم يكن موجوداً فكان لا بد أن يُكتب.

ولم أرد كتاباً يترجم ما كُتب في بلاد أخرى ثم يلحق به فصلاً عن الخليج، بل كتاباً يبدأ من هنا، تُذكر فيه أطر مصارفنا المركزية وهيئاتنا الوطنية وقوانين بياناتنا في موضعها من كل فصل، وتُروى فيه حوادث منطقتنا وأخطاء مؤسساتنا وما ينجح فيها حقاً، وتجدر فيه الجامعات والجهات الحكومية مادة تبني عليها، وتُنشر تدريباته وأشكاله وأدواته مفتوحة ليبنى عليها غيري.

ولا يدعي الكتاب أنه الكلمة الأخيرة في مجال يتبدل كل عام، بل هو كلمة أولى أردتها متينة بما يكفي ليبنى عليها، فإن وجدت فيه ما ينفع فأنشره، وإن وجدت فيه خطأً فراسلني، وإن علمته غيرك فقد أمسكت الحبل لمن بعدك.

علي العنزي، الكويت، 2026.

المقدمة

لم أجد في بداية طريقي المرجع العربي الذي كنت أتمنى أن أقرأه، فالمراجع الأجنبية غزيرة لكنها تخاطب واقعاً غير واقعنا، أنظمة لا نخضع لها وأمثلة لا نعيشها ومصطلحاً لا يعرفه زملاؤنا، والمحتوى العربي متناثر بين ترجمات حرفية ومقالات متفرقة لا يجمعها خيط واحد، فكان على من يتعلم المجال في منطقتنا أن يجمعه بنفسه من عشرات المصادر، وهذا الكتاب محاولة لأن يجده من يأتي بعدي مجموعاً.

يخاطب الكتاب ثلاث فئات من القراء، فهو مدخل منظم لطالب الجامعة والمبتدئ الذي يريد أن يفهم المجال من جذوره، ومرجع عملي للمهندس والمحلل الذي يعمل في الميدان ويحتاج إلى تثبيت المفاهيم وربطها بعضها ببعض، وخريطة واضحة للمدير والقيادي والمسؤول الحكومي الذي يتخذ قرارات تمس أمن مؤسسته دون أن يكون متخصصاً في التفاصيل التقنية، وقد كُتب ليكون مرجعاً تعتمد عليه الجامعات في مقرراتها والجهات الحكومية في برامج التأهيل، ويشرح دليل القراءة في الصفحات التالية كيف يستفيد منه كل قارئ بحسب حاجته.

قسمت الكتاب إلى أربعة أبواب، يضع الباب الأول الأسس من مفاهيم وتهديدات ومخاطر وحكمة، ويتناول الباب الثاني الضوابط التقنية من التشفير إلى الأنظمة الصناعية ويختتمها بفصل المعمارية الأمنية الذي

يجمعها في تصميم واحد، ويعالج الباب الثالث العمليات والصمود من المراقبة إلى الاستجابة والتعافي والعنصر البشري، ويطل الباب الرابع على الآفاق في الذكاء الاصطناعي والمسيرة المهنية، وتختتم الملاحق بقائمة تحقق للمؤسسة الصغيرة ومسرد شامل ومراجع.

وفي الختام فإن هذا الكتاب جهد بشري قابل للخطأ والتحسين، فإن وجدت فيه خطأ أو كان لديك اقتراح فراسلني على info@3li.info وسأكون ممتناً لك، وأسأل الله أن ينفع به كل من قرأه.

كيف تقرأ هذا الكتاب

يختلف القراء فيما يحتاجونه من هذا الكتاب، ولذلك رُسمت أربعة مسارات للقراءة، فالطالب والمبتدئ يقرآن الأبواب بترتيبها لأن كل فصل يبني على ما قبله ويحيل إليه، والممارس يبدأ من الفصل الذي يحتاجه مباشرة ويرجع إلى الباب الأول حين يصادف مفهوماً يحتاج إلى تثبيت، والقيادي والمسؤول الحكومي يقرآن الباب الأول كاملاً ثم الفصل الثالث عشر عن المعمارية والباب الثالث عن العمليات والصمود لأنها الفصول التي تمس قراراتهما، والمدرّب والأستاذ الجامعي يبنيان المقرر على أهداف التعلم في أول كل فصل والتمارين في آخره ويجدان التدريبات والقوالب والأشكال في المستودع المرافق.

وتتبع فصول الكتاب بنية واحدة، فيبدأ كل فصل بصندوق أهداف التعلم ثم مقدمة تربط الموضوع بالواقع، ثم الأقسام وفيها شكل توضيحي واحد على الأقل وأمثلة ودراسة حالة في كثير منها، ثم أخطاء شائعة تتكرر في مؤسسات المنطقة، ثم قائمة تحقق يقيس بها القارئ مؤسسته، ثم خلاصة الفصل، ثم جدول المصطلحات بالعربية والإنجليزية، ثم خريطة إلى الأطر الدولية والخليجية التي يقابلها الفصل، ثم أسئلة للمراجعة، ثم تمارين تطبيقية، ثم مصادر للتعمق.

واتُبعَت في الكتاب مواضع ثابتة، فالمصطلح الإنجليزي يُذكر بين قوسين عند أول ورود له في كل فصل ويُجمع المسرد في آخر الكتاب، والأرقام بالأرقام الغربية، وأسماء الأطر والمعايير بأسمائها الرسمية مع رمزها الدولي، والأمثلة لا تذكر مؤسسات بعينها إلا ما صار حدثاً عاماً موثقاً، وحين يُذكر إطار خليجي فالمقصود إصداره النافذ وقت الكتابة، ويحسن الرجوع إلى الجهة المصدرة لأحدث إصدار، وتجد التدريبات والقوالب والأشكال والأدوات في موقع الكتاب gulfcyber.3li.info وفي مستودعه المفتوح، وتجد قناة لإبلاغ الأخطاء واقتراح التحسينات في الموقع نفسه.

شكر وتقدير

لم يكتب هذا الكتاب في عزلة، فكل فكرة فيه مرت بنقاش مع زميل أو اختبار في ميدان أو سؤال من طالب، فالشكر لزملائي في القطاع المالي الخليجي الذين تعلمت منهم أن الأمن قرار قبل أن يكون أداة، ولأعضاء لجان الأمن السيبراني القطاعية الذين يثبتون كل أسبوع أن المؤسسات تحمي بعضها حين تتشارك، وللجهات المنظمة في دول المجلس التي حولت الأمن من توصية إلى إطار، ولطلابي ومتدربي الذين كانت أسئلتهم أصدق مراجعة لكل فصل، وللمجتمع المصادر المفتوحة الذي بُنيت بأدواته تدريبات هذا الكتاب وأشكاله وغلافه، ولأسرتي التي تحملت ساعات الكتابة الطويلة وكانت أول من قرأ، فما فيه من صواب فبفضلهم جميعاً وما فيه من خطأ فعلي وحدي.

الباب الأول

الأسس

الفصل الأول

مدخل إلى أمن المعلومات

أهداف التعلم: بعد دراسة هذا الفصل ستكون قادراً على:

- تعريف المعلومات وتمييزها عن البيانات والمعرفة وبيان سبب حمايتها
- شرح خصائص السرية والسلامة والتوافر والخصائص المكتملة لها بأمثلة
- التمييز بين أمن المعلومات والأمن السبراني وحماية البيانات
- استخدام مفردات الأصل والتهديد والثغرة والخطر والضابط استخداماً صحيحاً
- تصنيف الضوابط بطبيعتها ووظيفتها وشرح المبادئ الثابتة للحماية

في صباح يوم عمل عادي يصل مدير العمليات في شركة متوسطة إلى مكتبه فيجد شاشات الموظفين كلها تعرض رسالة واحدة تخبره بأن ملفات الشركة سُفِّرت وأن استعادتها تتطلب دفع مبلغ بعملة رقمية في غضون ثلاثة أيام، فتتوقف الفواتير والرواتب والعقود دفعة واحدة، ويكتشف الجميع في تلك

للحظة أن الشركة لم تكن تبّيع منتجات فحسب بل كانت تقوم على معلومات لم يفكر أحد في حمايتها جدياً.

تتكرر هذه القصة كل يوم بأشكال مختلفة في المستشفيات والجامعات والجهات الحكومية والبنوك والمتاجر الصغيرة، وما يجمع بين ضحاياها ليس ضعف التقنية وحدها بل غياب الفهم المنظم لما ينبغي حمايته ومن يهدده وكيف تُبنى الحماية، ولهذا يبدأ هذا الكتاب من الأساس، أي من تعريف المعلومات وخصائصها التي نحميها والمفردات التي يتحدث بها المختصون والمبادئ التي لا تتغير مهما تغيرت التقنية.

1.1 ما المعلومات ولماذا نحميها

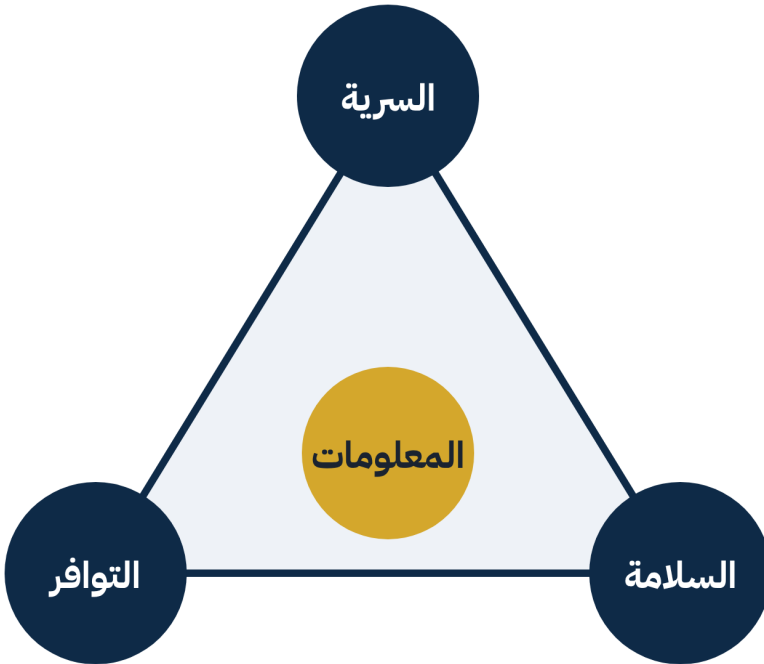
تبدأ الحكاية بالبيانات (Data) وهي حقائق خام لا معنى لها في ذاتها كرقم هاتف منفرد أو تاريخ أو مبلغ، فإذا رُتبت هذه البيانات في سياق صارت معلومات (Information) كأن نعرف أن هذا الرقم يخص عميلاً بعينه وأن ذلك المبلغ هو رصيده في تاريخ محدد، وإذا تراكمت المعلومات وفُسرت صارت معرفة (Knowledge) تُبنى عليها القرارات، ونحن نحكي المعلومات لأن لها قيمة، فقيمتها قد تكون مالية كبيانات البطاقات المصرفية، أو قانونية كالعقود والسجلات الطبية، أو تنافسية تخطط المنتجات وأسعار العطاءات، أو إنسانية كصور العائلة وأسرار المرضى، وقد تكون قيمتها في مجرد توافرها في اللحظة المناسبة كبيانات المريض على طاولة العمليات.

ولا تعيش المعلومات في الحاسوب وحده، فهي في الورق المطبوع وفي الأحاديث الجانبية وفي ذاكرة الموظفين وفي الرسائل النصية وفي الصور الملتقطة بالهاتف، ولهذا يتحدث المختصون عن حالات المعلومات

الثلاث، أي المعلومات أثناء التخزين (At Rest) على الأقراص والنسخ الاحتياطية، وأثناء النقل (In Transit) عبر الشبكات والبريد، وأثناء الاستخدام (In Use) في ذاكرة التطبيقات وعلى الشاشات، فالحماية التي تغطي حالة واحدة وتهمل الآخرين تشبه باباً محصناً في بيت بلا جدران.

وتمر المعلومات بدورة حياة تبدأ بالإنشاء ثم التخزين ثم الاستخدام والمشاركة ثم الأرشفة ثم الإتلاف، ويحتاج كل طور من هذه الأطوار إلى حماية تناسبه، فالمعلومة التي أُتلفت بطريقة غير صحيحة قد تعود إلى الظهور من قرص بيع في سوق المستعمل، والمعلومة التي شُرِكت مع طرف ثالث خرجت من نطاق سيطرتك ما لم تُضبط هذه المشاركة بعقد وضوابط.

2.1 الخصائص الثلاث: السرية والسلامة والتوافر



شكل 1.1: ثلاث السرية والسلامة والتوافر

يتفق المختصون على أن حماية المعلومات تعني الحفاظ على ثلاث خصائص أساسية يُعرف مجموعها بثلاث السرية والسلامة والتوافر (CIA Triad)، وكل خاصية منها تجيب عن سؤال مختلف، فالسرية (Confidentiality) تجيب عن سؤال من يحق له أن يرى هذه المعلومة، والسلامة (Integrity) تجيب عن سؤال هل هذه المعلومة صحيحة ولم تُغيّر دون إذن، والتوافر (Availability) يجيب عن سؤال هل المعلومة موجودة حين نحتاجها.

وتُنتهك السرية حين يُطلع على المعلومة من لا يحق له ذلك، سواء أكان مهاجماً سرق قاعدة بيانات العملاء أم موظفاً فضولياً فتح ملف زميله الطبي أم جهازاً ضاع في سيارة أجرة وفيه نسخة غير مشفرة من العقود، وتشمل أدوات حفظ السرية التشفير وضبط الصلاحيات وتصنيف المعلومات والتدريب على عدم إفشائها.

وتُنتهك السلامة حين تُغيّر المعلومة أو تُحذف أو تُفبرك دون صلاحية، كأن يعدل موظف رصيداً في النظام أو يغير مهاجم رقم الحساب في فاتورة مرسلة بالبريد لتذهب الحوالة إلى حسابه هو، وقد تُنتهك السلامة دون نية خبيثة خطأً في البرمجة يفسد السجلات أو عطل في القرص، وتشمل أدوات حفظ السلامة دوال التجزئة (Hash Functions) والتوقيع الرقمي وسجلات التدقيق والفصل بين المهام وضوابط التحقق من المدخلات.

ويُنتهك التوافر حين تصبح المعلومة أو الخدمة غير متاحة في الوقت الذي يحتاجها فيه أصحابها، كهجوم حجب الخدمة الذي يعطل بوابة حكومية في موسم تقديم الطلبات أو برمجية فدية تغلق نظام مستشفى أو انقطاع كهرباء في مركز بيانات بلا مولد احتياطي، وتشمل أدوات حفظ التوافر التكرار (Redundancy) والنسخ الاحتياطي وخطط الاستمرارية والحماية من حجب الخدمة.

ولا يعني الثالث أن الخصائص الثلاث متساوية الأهمية في كل سياق، فالسرية هي الأولوية القصوى في بيانات الاستخبارات، بينما يتقدم التوافر في أنظمة التحكم الصناعي التي يعني توقفها خطراً على الأرواح، وتتقدم السلامة في الأنظمة المالية التي يهدد التلاعب بها الثقة كلها، ولهذا تبدأ أي حماية جادة بسؤال بسيط عن الخاصية التي يضر فقدانها أكثر من غيرها في هذا النظام تحديداً.

وقد أضاف المختصون إلى الثالث خصائص مكملة يرد ذكرها كثيراً في المعايير والعقود، وهي الأصالة (Authenticity) أي التأكيد من أن المعلومة صادرة عن يدعي إصدارها، وعدم الإنكار (Non-repudiation) أي عجز الطرف عن إنكار فعل صدر عنه كتوقيع عقد أو إرسال أمر تحويل، والمساءلة (Accountability) أي إمكانية نسبة كل فعل في النظام إلى شخص محدد، والخصوصية (Privacy) أي حق الأفراد في التحكم بمعلوماتهم الشخصية، وهو ما أصبح له في دول الخليج أنظمة وقوانين خاصة سنفلها في فصل أمن البيانات.

جدول 1.1: الخصائص الثلاث وما يحفظها

الخاصية	السؤال الذي تجيب عنه	مثال على انتهاكها	ضوابط نمذجية
السرية	من يحق له الاطلاع	تسريب قاعدة بيانات العملاء	التشفير وضبط الصلاحيات والتصنيف
السلامة	هل المعلومة صحيحة وغير معدلة	تغيير رقم حساب في فاتورة	التجزئة والتوقيع الرقمي وسجلات التدقيق
التوافر	هل المعلومة متاحة وقت الحاجة	تعطل بوابة خدمات في موسم الذروة	التكرار والنسخ الاحتياطي وخطط الاستمرارية

3.1 أمن المعلومات والأمن السيبراني وحماية البيانات

تداخل هذه المصطلحات الثلاثة في الاستخدام اليومي حتى يظنها كثيرون شيئاً واحداً، غير أن لكل منها نطاقاً مختلفاً، فأمن المعلومات (Informa-tion Security) هو المظلة الأوسع لأنه يُعنى بحماية المعلومات بأي شكل كانت رقمية أو ورقية أو شفوية، أما الأمن السيبراني (Cybersecurity) فيركز على حماية الأنظمة الرقمية والشبكات والبيانات التي تمر عبرها من الهجمات الإلكترونية، فهو جزء من أمن المعلومات وإن كان الجزء الأكبر والأكثر حضوراً في عصرنا، وأما حماية البيانات (Data Protection) فتتطرق إلى المسألة من زاوية الحقوق والقانون، أي حق الفرد في أن تُجمع بياناته الشخصية وتُعالج وتُحفظ وفق قواعد واضحة تحترم خصوصيته.

ويساعد التمييز بين النطاقات الثلاثة على تحديد المسؤوليات داخل المؤسسة، فحماية الوثيقة الورقية في الأرشيف من الحريق والسرقة مسؤولية أمن المعلومات ولا علاقة لها بالشبكة، وصدد هجوم على الموقع الإلكتروني عمل سيبراني بحت، والإجابة عن سؤال هل يحق لنا الاحتفاظ ببيانات هذا العميل بعد انتهاء تعامله معنا سؤال في حماية البيانات يجيب عنه القانون والسياسة قبل التقنية، وفي الممارسة العملية تلتقي النطاقات الثلاثة في برنامج واحد يقوده الرئيس التنفيذي لأمن المعلومات (CISO) بالتعاون مع مسؤول حماية البيانات والمختصين القانونيين.

4.1 المفردات الأربع: الأصل والتهديد والثغرة والخطر

يتحدث المختصون بلغة تقوم على أربعة مصطلحات لا بد من إتقانها قبل أي شيء آخر، فالأصل (Asset) هو كل ما له قيمة للمؤسسة ويحتاج إلى حماية، وقد يكون معلومة كقاعدة بيانات أو نظاماً نكّاداً أو خدمة كالبوابة الإلكترونية أو إنساناً كموظف يحمل معرفة لا يملكها غيره أو سمعة يصعب استعادتها، والتهديد (Threat) هو أي حدث أو فاعل يمكن أن يلحق الضرر بالأصل سواء أكان مهاجماً أم موظفاً مهماً أم حريقاً أم عطلاً، والثغرة (Vulnerability) هي نقطة الضعف في الأصل أو في حمايته التي تتيح للتهديد أن يحقق ضرره كبرمجية لم تُحدّث أو كلمة مرور ضعيفة أو منفذ خادم مفتوح، والخطر (Risk) هو احتمال أن يستغل تهديد ثغرة في أصل مضرراً في حجم الأثر الناتج عن ذلك.

ويمكن تلخيص العلاقة بينها في معادلة بسيطة تقول إن الخطر هو حاصل اجتماع التهديد مع الثغرة مع الأثر، فإذا غاب أحد الثلاثة غاب الخطر، فالثغرة في نظام لا يهدده أحد لا تمثل خطراً حقيقياً، والتهديد الذي لا يجد ثغرة يستغلها يبقى تهديداً نظرياً، والاستغلال الذي لا يترتب عليه أثر لا يستحق الموارد، وعلى هذه المعادلة يقوم علم إدارة المخاطر كله الذي نفضله في الفصل الثالث.

ويرتبط بهذه المفردات مصطلح الضابط (Control) وهو الإجراء الذي نتخذه لتقليل الخطر إما بإزالة الثغرة أو بالحد من التهديد أو بتخفيف الأثر، ومصطلح الخطر المتبقي (Residual Risk) وهو ما يبقى من الخطر

بعد تطبيق الضوابط، لأن الخطر لا ينعلم أبداً مهما أنفقنا، وإنما نخفضه إلى مستوى تقبله المؤسسة وهي واعية بما تقبله.

5.1 مبادئ لا تتغير

تتغير التقنيات كل بضع سنوات لكن مبادئ الحماية ثابتة منذ عقود، وأول هذه المبادئ الدفاع في العمق (Defense in Depth) الذي يقضي بألا نعتمد على طبقة حماية واحدة مهما كانت قوية، بل نبني طبقات متتابعة بحيث إذا سقطت واحدة صدت التي بعدها، فالقلعة لها خندق وسور وأبراج وحرس وليس سوراً واحداً فقط، وثانيها مبدأ الامتياز الأدنى (Least Privilege) الذي يقضي بألا يُمنح أي شخص أو نظام من الصلاحيات إلا ما يحتاجه لأداء عمله ولا شيء أكثر، لأن كل صلاحية زائدة هي باب إضافي للمهاجم حين يستولي على ذلك الحساب.

وثالثها الفصل بين المهام (Segregation of Duties) الذي يمنع أن يكون الشخص الواحد قادراً على إتمام عملية حساسة من بدايتها إلى نهايتها وحده، فمن يدخل أمر الدفع لا يعتمد عليه، ومن يكتب البرنامج لا ينشره في بيئة الإنتاج، ورابعها افتراض الاختراق (Assume Breach) الذي يقضي بأن نصمم أنظمتنا على افتراض أن المهاجم موجود في الداخل، فنراقب ونجزئ ونحد من الحركة بدل أن نطمئن إلى أن السور لم يُخترق بعد، ومن هذا المبدأ انبثق نموذج انعدام الثقة (Zero Trust) الذي نفصله في فصل الهوية.

وخامسها البساطة، لأن النظام المعقد يصعب فهمه وتأمينه ومراجعته، وكل تعقيد زائد يخفي ثغرة محتملة، وسادسها الأمن بالتصميم والأمن افتراضياً (Secure by Design and by Default)، أي أن تُبنى

الحماية في المنتج منذ لحظة تصميمه وأن تكون إعداداته الأولية آمنة دون أن يحتاج المستخدم إلى ضبطها، لأن الحماية التي تُضاف في النهاية تكون أضعف وأعلى، وسابعها أن الإنسان جزء من النظام، فأقوى تشفير في العالم لا يحمي كلمة مرور كتبها صاحبها على ورقة ملصقة بالشاشة، ولذلك خصصنا لهذا الجانب فصلاً كاملاً.

6.1 أنواع الضوابط

تُصنف الضوابط من زاويتين، فمن زاوية طبيعتها تنقسم إلى ضوابط إدارية (Administrative) كالسياسات والإجراءات والتدريب والعقود، وضوابط تقنية (Technical) كالجدران النارية والتشفير وأنظمة كشف التسلل، وضوابط مادية (Physical) كالأبواب والكاميرات والحراسة والأقفال، ولا تكتمل حماية بغير الأنواع الثلاثة لأن الجدار الناري لا يمنع موظفاً من إدخال غريب إلى غرفة الخوادم، والسياسة المكتوبة لا تمنع هجوماً آلياً على الشبكة.

ومن زاوية وظيفتها تنقسم الضوابط إلى خمس وظائف، فالضابط الوقائي (Preventive) يمنع الحدث قبل وقوعه كالمصادقة متعددة العوامل، والضابط الكاشف (Detective) يكتشف الحدث حين يقع أو بعده كأنظمة المراقبة وسجلات التدقيق، والضابط التصحيحي (Corrective) يعالج أثر الحدث كاستعادة النسخ الاحتياطية، والضابط الرادع (Deterrent) يثني المهاجم عن المحاولة كلافقات التحذير والعقوبات المعلنة، والضابط التعويضي (Compensating) يحل محل ضابط أساسي تعذر تطبيقه كمراقبة مشددة لنظام قديم لا يمكن تحديثه.

جدول 2.1: وظائف الضوابط الخمس

الوظيفة	ماذا تفعل	أمثلة
وقائي	يمنع الحدث قبل وقوعه	المصادقة متعددة العوامل والتشفير
كاشف	يكشف الحدث عند وقوعه	أنظمة كشف التسلل وسجلات التدقيق
تصحيحي	يعالج أثر الحدث	استعادة النسخ الاحتياطية
رادع	يثني عن المحاولة	التحذيرات والعقوبات المعلنة
تعويضي	يحل محل ضابط متعذر	مراقبة مشددة لنظام قديم

7.1 لماذا تُخترق المؤسسات مع كل هذا

تكشف تحقيقات الحوادث عاماً بعد عام أن معظم الاختراقات لا تقع بسبب تقنيات هجوم متقدمة بل بسبب أخطاء معروفة، فثغرة لم تُرَقَّع مع أن تحديثها متاح منذ شهور، وحساب يحمل صلاحيات مدير بكلمة مرور تُستخدم في موقع آخر تسربت منه، وخدمة سحابية تركت مفتوحة للجميع بإعداد خاطئ، وموظف ضغط على رابط في رسالة بدت من مديره، ومورد خارجي يملك وصولاً إلى الشبكة دون أن يعرف أحد ما يفعله به، وغياب شبه كامل للرؤية بحيث يبقى المهاجم في الشبكة أسابيع قبل أن يلاحظه أحد.

والقاسم المشترك بين هذه الأسباب أنها ليست مشكلات تقنية صرفة بل مشكلات في الإدارة والثقافة والانضباط، فالمؤسسة التي تعرف أصولها وتصنفها وتحديث أنظمتها وتضبط صلاحياتها وتراقب شبكتها وتدريب موظفيها تصد الغالبية العظمى من الهجمات بأدوات متاحة للجميع، أما المؤسسة التي تشتري أعلى المنتجات دون هذه الأساسيات فهي تضع قفلاً ذهبياً على باب مفتوح.

8.1 الأمن عملية مستمرة لا منتج يُشتري

يُختم هذا الفصل بالفكرة التي تحكم الكتاب كله، وهي أن أمن المعلومات ليس حالة تصل إليها المؤسسة ثم تستريح، بل عملية دائرة لا تتوقف لأن الأصول تتغير والتهديدات تتطور والثغرات تُكتشف كل يوم، ويلخص إطار الأمن السيبراني الصادر عن المعهد الوطني الأمريكي للمعايير والتقنية (NIST CSF) هذه العملية في وظائف متتابعة تبدأ بالحوكمة ثم تحديد الأصول والمخاطر ثم الحماية ثم الكشف ثم الاستجابة ثم التعافي، وتعود الدائرة إلى بدايتها بما تعلته المؤسسة من كل جولة، وعلى هذا الترتيب تقريباً بُنيت أبواب هذا الكتاب.

أخطاء شائعة

- شراء المنتجات قبل جرد الأصول وتصنيفها، فتحمل أشياء لا تهم وتترك الأهم
- الخلط بين الأمن السيبراني وأمن المعلومات فتُهمل الوثائق الورقية والأحداث والعنصر البشري

- الاعتماد على ضابط وقائي واحد كالجدار الناري دون كشف ولا تصحيح
- معاملة الخطر باعتباره شيئاً يُزال بالكامل بدل أن يُخفّض إلى مستوى مقبول وموثق
- ترك قرار قبول الخطر لمدير تقنية المعلومات بدل مالك العملية

قائمة تحقق

1. قائمة أصول محدثة بمالك لكل أصل
2. تصنيف للمعلومات من ثلاثة إلى أربعة مستويات مطبق فعلاً
3. لكل أصل حرج ضوابط وقائية وكاشفة وتصحيحية
4. الخصائص الثلاث محددة الأولوية لكل نظام حرج
5. مبدأ الامتياز الأدنى مطبق على الحسابات المميزة على الأقل
6. الفصل بين المهام في العمليات المالية والنشر
7. سجل بالمخاطر المتبقية المقبولة وموقع من قبلها
8. دورة مراجعة دورية للضوابط لا مشروع ينتهي

خلاصة الفصل

- المعلومات أصل له قيمة وتوجد في ثلاث حالات هي التخزين والنقل والاستخدام، وتتم بدورة حياة من الإنشاء إلى الإتلاف
- نحجي ثلاث خصائص هي السرية والسلامة والتوافر، وتضاف إليها الأصالة وعدم الإنكار والمساءلة والخصوصية
- أمن المعلومات مظلة أوسع من الأمن السيبراني، بينما تنظر حماية البيانات من زاوية الحقوق والقانون

- الخطر هو اجتماع تهديد مع ثغرة في أصل مع أثر، والضوابط تخفضه إلى خطر متبقي مقبول
- المبادئ الثابتة هي الدفاع في العمق والامتياز الأدنى والفصل بين المهام واقتراض الاختراق والبساطة والأمن بالتصميم
- الضوابط إدارية وتقنية ومادية بطبيعتها، ووقائية وكاشفة وتصحيحية ورادعة وتعويزية بوظيفتها

المصطلحات الأساسية

المصطلح	بالإنجليزية
السرية	Confidentiality
السلامة	Integrity
التوافر	Availability
عدم الإنكار	Non-repudiation
الأصل	Asset
التهديد	Threat
الثغرة	Vulnerability
الخطر	Risk
الضابط	Control
الخطر المتبقي	Residual Risk
الدفاع في العمق	Defense in Depth
الامتياز الأدنى	Least Privilege

خريطة إلى الأطر

يؤسس هذا الفصل للمفاهيم التي تقوم عليها كل الأطر، فالخصائص الثلاث هي تعريف أمن المعلومات في المعيار الدولي ISO/IEC 27000، ودورة الوظائف من الحوكمة إلى التعافي هي بنية إطار NIST CSF في إصداره الثاني، ومفردات الأصل والتهديد والثغرة والخطر هي لغة فصول إدارة المخاطر في الأطر الخليجية كلها.

أسئلة للمراجعة

1. ما الفرق بين البيانات والمعلومات والمعرفة، وأيها نلجي؟
2. اذكر نظاماً تتقدم فيه السلامة على السرية وعلل اختيارك؟
3. لماذا لا يكفي ضابط وقائي واحد مهما كانت قوته؟
4. ما الخطر المتبقي ومن يقرر قبوله؟
5. صنف الضوابط الآتية بطبيعتها ووظيفتها: كاميرا المراقبة، وسياسة كلمات المرور، ونظام النسخ الاحتياطي، وتشفير القرص؟
6. لماذا يوصف أمن المعلومات بأنه عملية لا منتج؟

تمارين تطبيقية

1. اختر نظاماً تتعامل معه يومياً كتطبيق البنك أو بوابة الجامعة، وحدد لكل خاصية من الخصائص الثلاث مثلاً على انتهاكها وأثر ذلك عليك
2. أعد قائمة بعشرة أصول في مؤسسة صغيرة تتخيلها وصنف كل أصل بحسب الخاصية التي يضر فقدانها أكثر

3. صنف خمسة عشر ضابطاً تعرفها في جدول من بعدين هما الطبيعة والوظيفة ولاحظ الخانات الفارغة

للتعمق ومصادر الفصل

- المعيار الدولي ISO/IEC 27000 للمصطلحات والمفاهيم الأساسية
- إطار NIST CSF في إصداره الثاني ووثيقته التعريفية
- الضوابط الحرجة CIS Controls في إصدارها الثامن ودليل مجموعات التطبيق
- المسرد الرسمي للأمن السيبراني الصادر عن الهيئة الوطنية للأمن السيبراني في السعودية